

NOMBRE: ENYA MIRANDA FLORES **FECHA: 26 DE OCTUBRE DEL 2026**

INTRODUCCIÓN:

En el ámbito de la ciberseguridad web, la identificación temprana de vulnerabilidades es esencial para proteger la integridad de las aplicaciones y la privacidad de los usuarios. Esta actividad se enfoca en la realización de un análisis de seguridad práctico utilizando OWASP ZAP (Zed Attack Proxy), una de las herramientas de escaneo y auditoría web más reconocidas a nivel mundial. A través de un entorno controlado en Kali Linux, se interceptó y analizó el tráfico HTTP de un sitio web objetivo para comprender la estructura de una aplicación web.

OBJETIVO DE LA ACTIVIDAD:

Evaluar el nivel de seguridad del sitio web objetivo (https://ginandjuice.shop/) mediante un escaneo dinámico e intercepción de tráfico con OWASP ZAP. El propósito es identificar y clasificar sus principales vulnerabilidades para proponer medidas de mitigación y consolidar conocimientos prácticos en seguridad web.

METODOLOGIÍA:

Para llevar a cabo la evaluación de seguridad en (https://ginandjuice.shop/) se siguió un procedimiento práctico estructurado en cinco pasos:

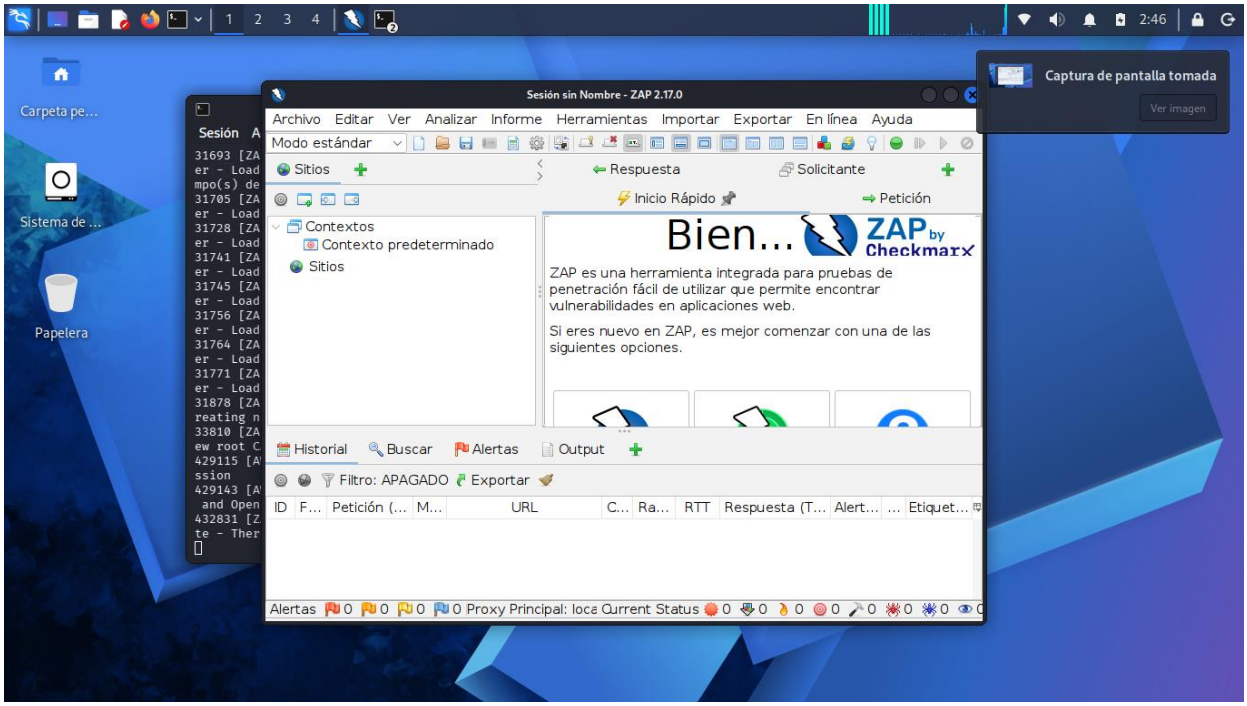
1. Preparación del entorno
2. Exploración y mapeo de la aplicación
3. Análisis de alertas
4. Documentación del hallazgo
5. Cierre del entorno



EVALUACIÓN DE SEGURIDAD WEB

1) **Preparación del Entorno de Red:** Se configuró el navegador Firefox en Kali Linux para canalizar la navegación a través de un proxy local (127.0.0.1:8080), permitiendo a OWASP ZAP interceptar todo el tráfico entrante y saliente.

1.1) ZAP Abierto**:** Captura de la interfaz principal de OWASP ZAP.



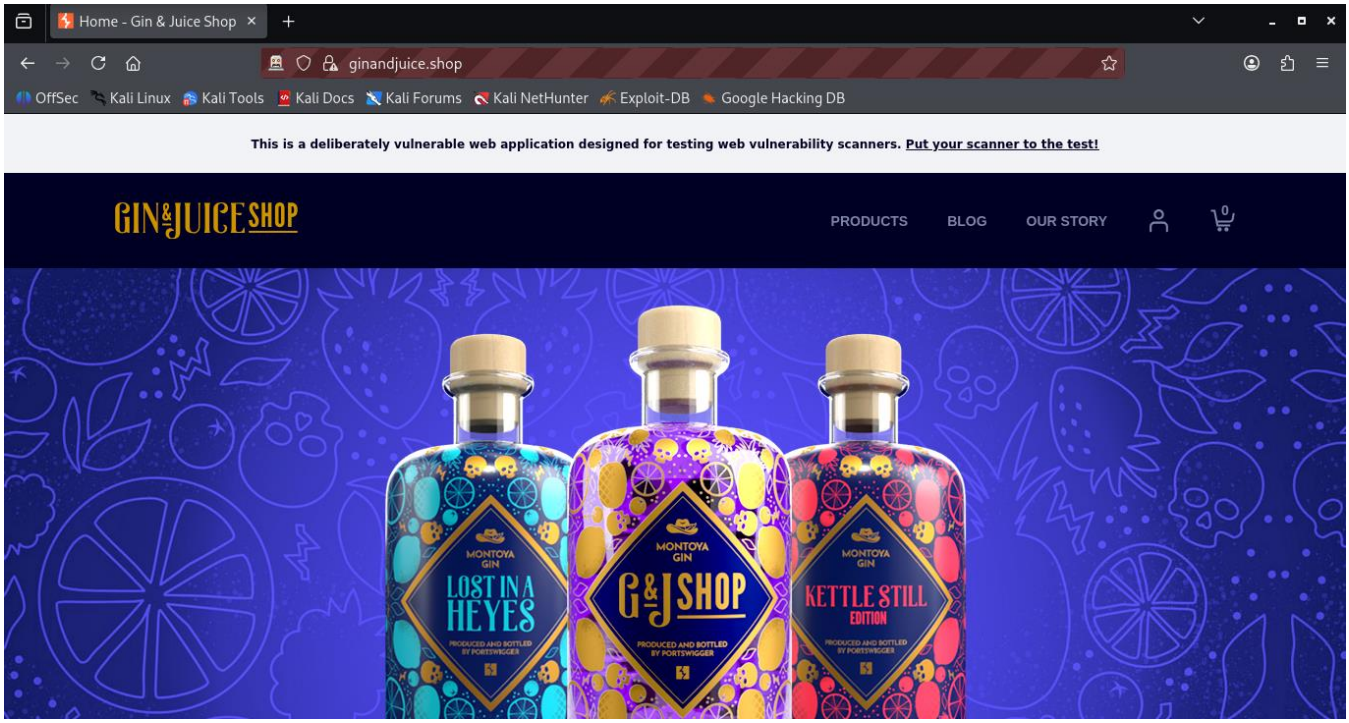
1.2) Navegador configurado: El navegador Firefox abierto automáticamente a través del proxy de ZAP.



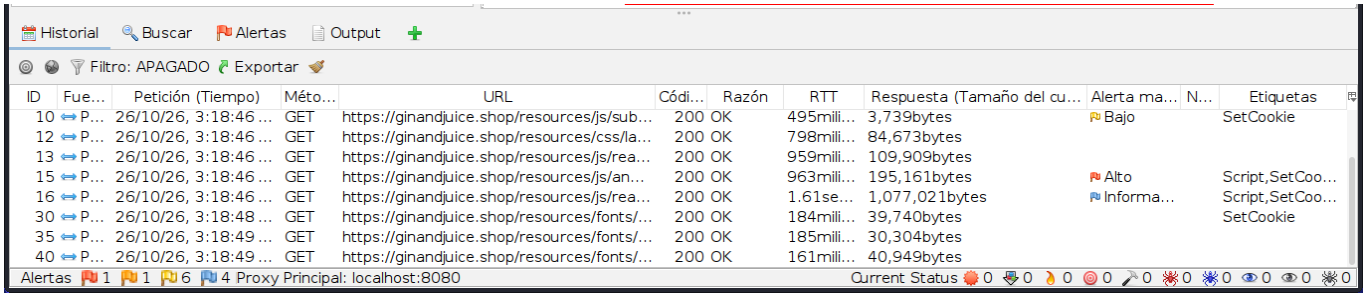
1.3) Acceso a [https://ginandjuice.shop/]



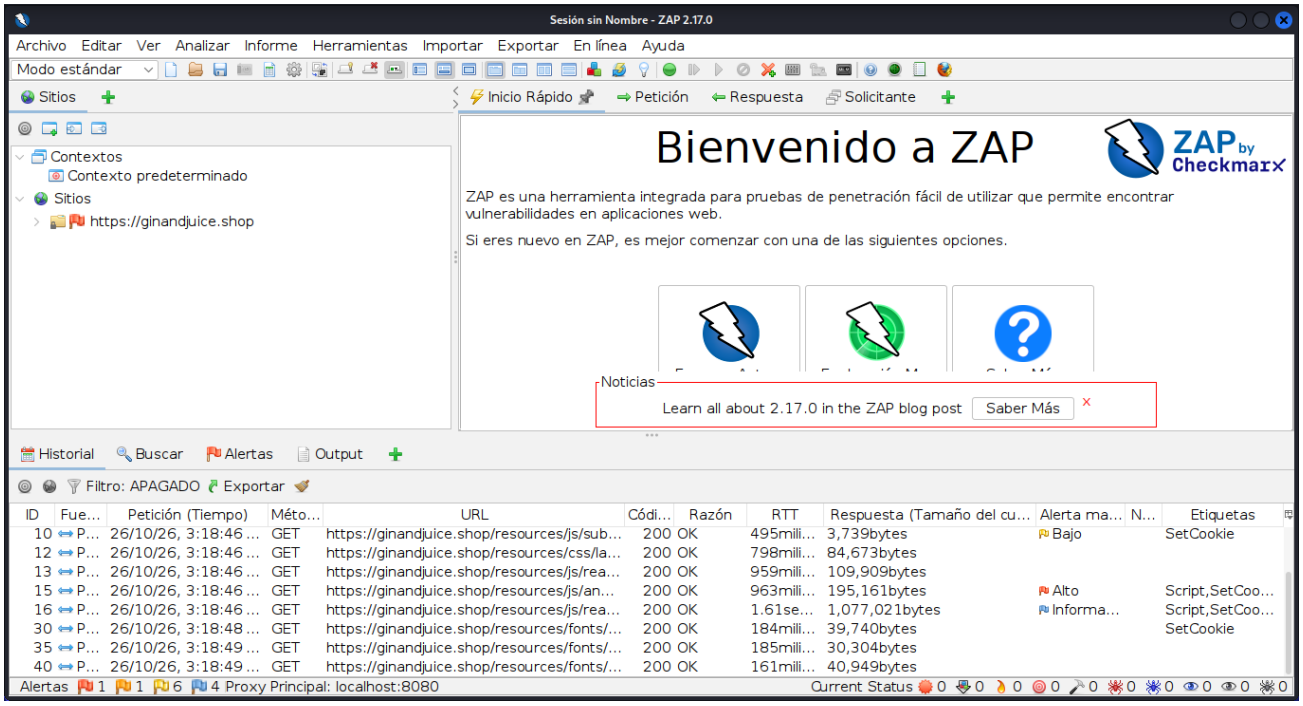




1.4) Verificación de tráfico en ZAP: foto de la pestaña **Historial** mostrando las peticiones GET 200 OK.





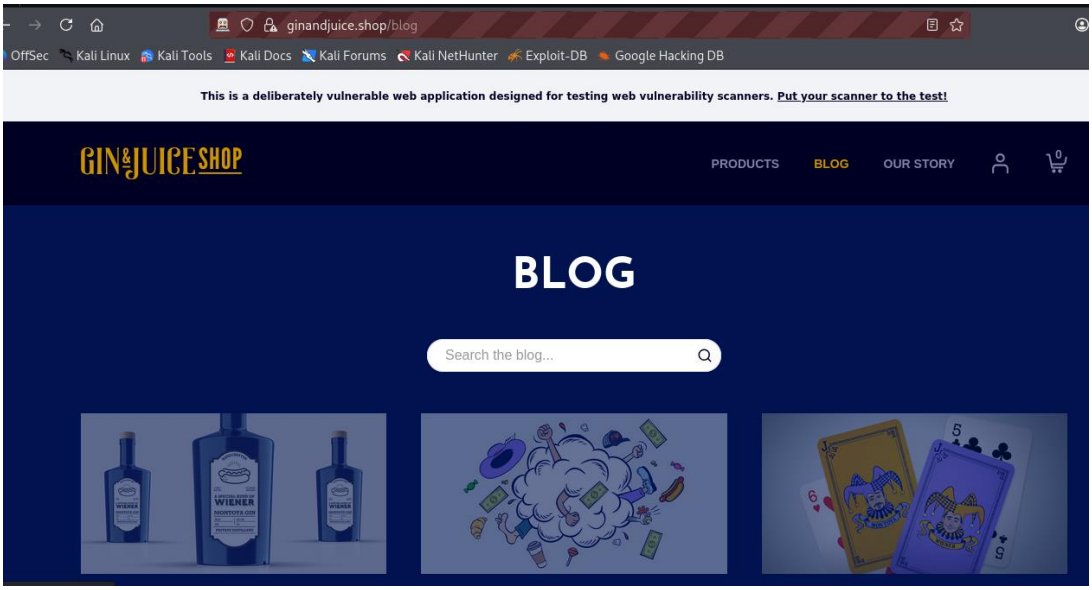


2) **Exploración y Mapeo de la Aplicación:** Se realizó una navegación interactiva por las distintas secciones del sitio objetivo (/catalog, /about, /cart), registrando las peticiones HTTP (GET/POST) y mapeando la estructura mediante la herramienta Araña (*Spider*) de ZAP.

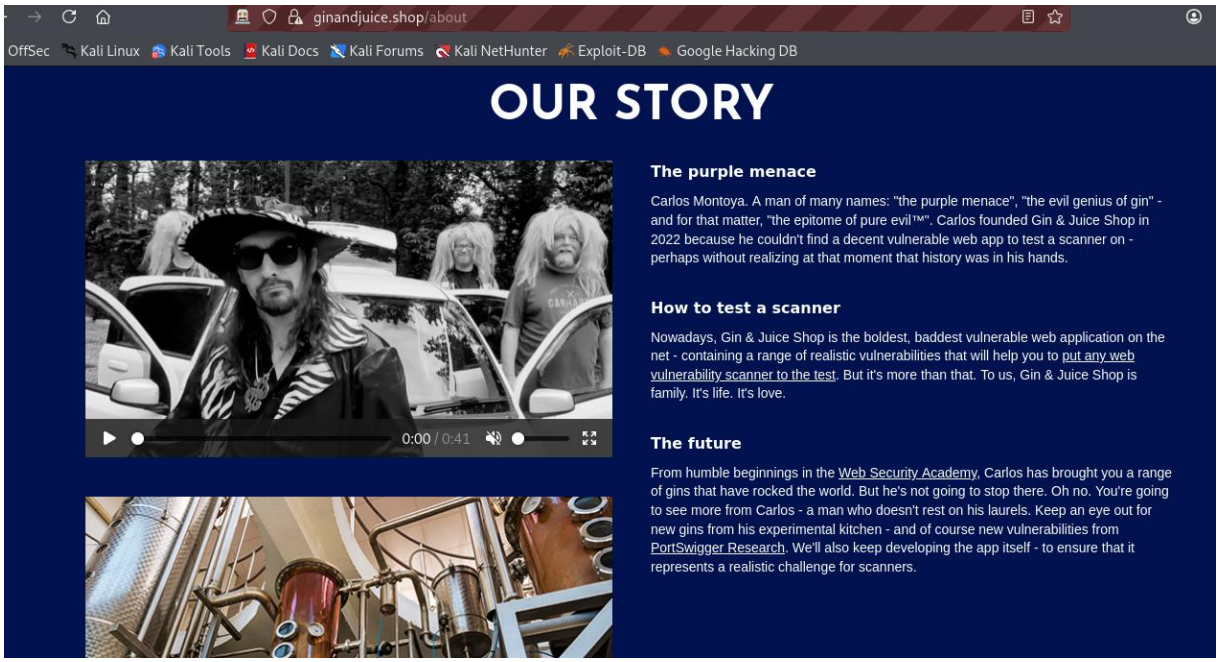
2.1) Navegación por el sitio web: 5 sitios a explorar

1. **Blog / Publicación:**
   https://ginandjuice.shop/blog/post?postId... (ID 394)



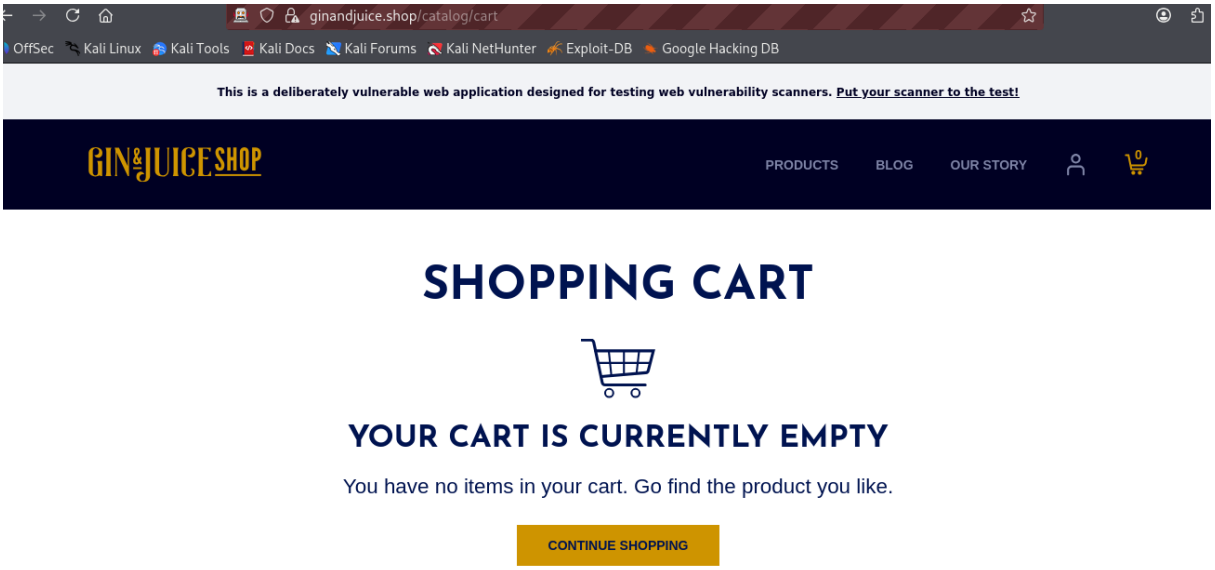


2. **Nuestra Historia / Acerca de:**
https://ginandjuice.shop/about (ID 396)

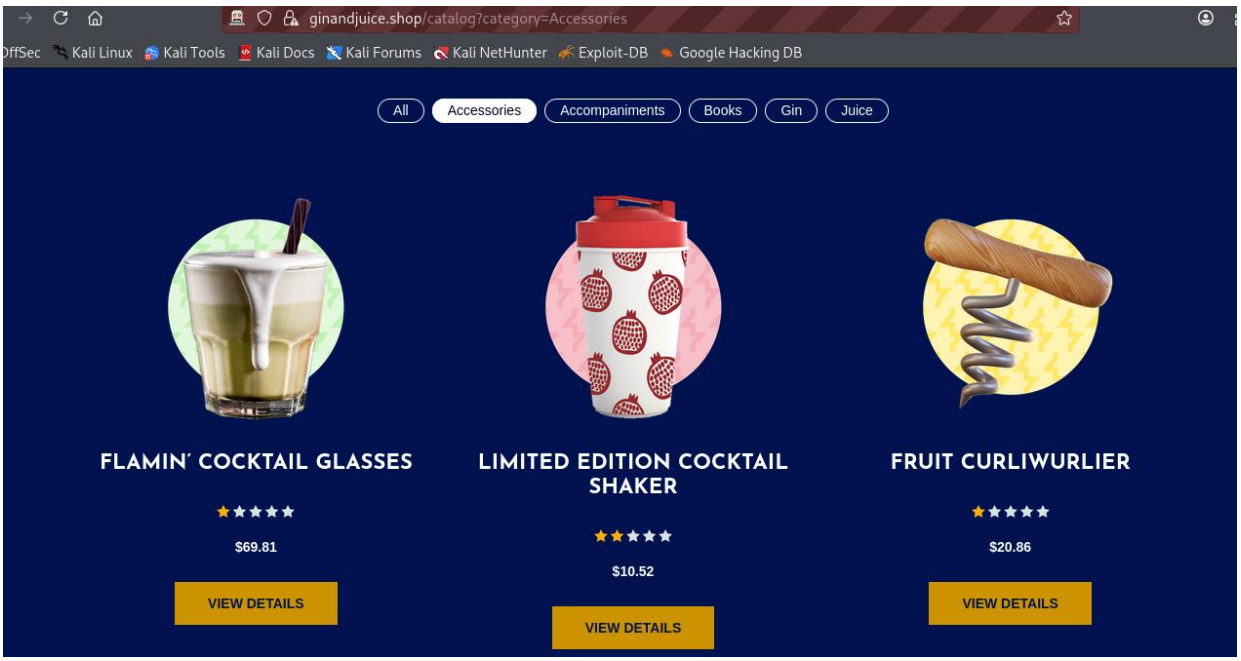


3. **Carrito de Compras:**
https://ginandjuice.shop/catalog/cart (ID 406)





4. **Catálogo de Productos:**
https://ginandjuice.shop/catalog (ID 409)





5. **Recursos / Imágenes del sitio:** https://ginandjuice.shop/resources/imag... (ID 404 / 405)



2.2) Tráfico HTTP en ZAP: Captura del tráfico al navegar por los sitios. Se verifica el registro de las peticiones HTTP (GET/POST) en la pestaña Historial de OWASP ZAP correspondientes a la navegación manual realizada en las 5 secciones del sitio web

1. **Blog / Publicación:** https://ginandjuice.shop/blog/post?postId... (ID 394)

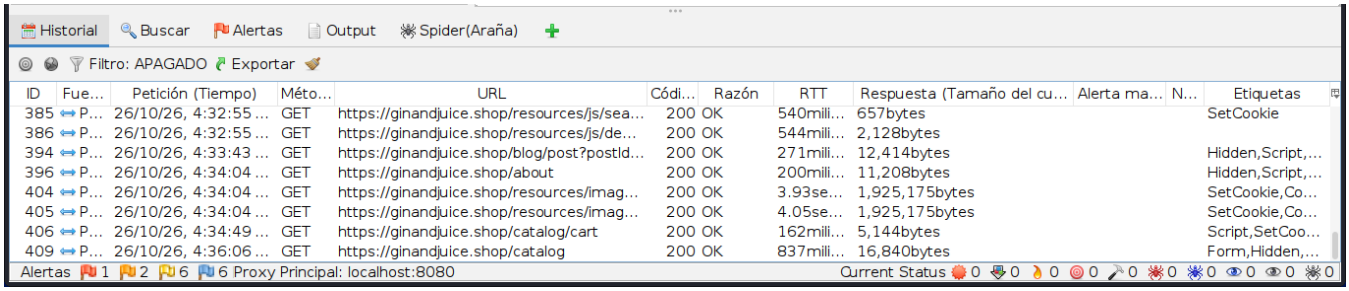
2. **Nuestra Historia / Acerca de:** https://ginandjuice.shop/about (ID 396)

3. **Carrito de Compras:** https://ginandjuice.shop/catalog/cart (ID 406)

4. **Catálogo de Productos:** https://ginandjuice.shop/catalog (ID 409)

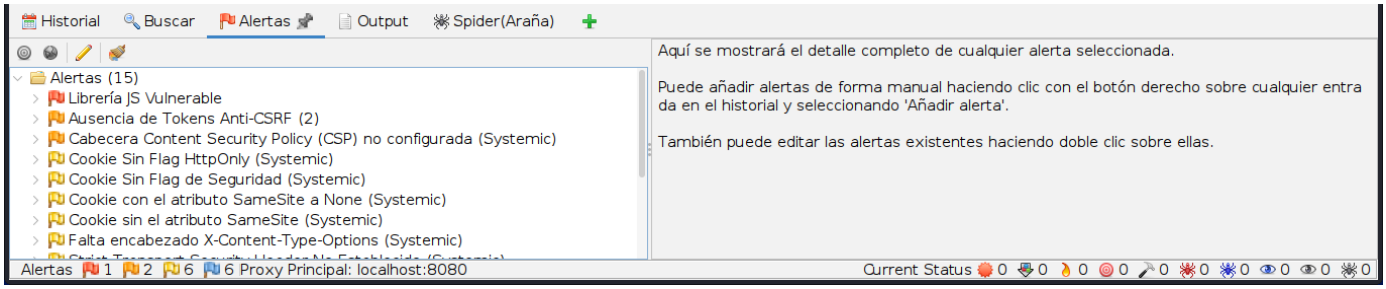
5. **Recursos / Imágenes del sitio:** https://ginandjuice.shop/resources/imag... (ID 404 / 405)

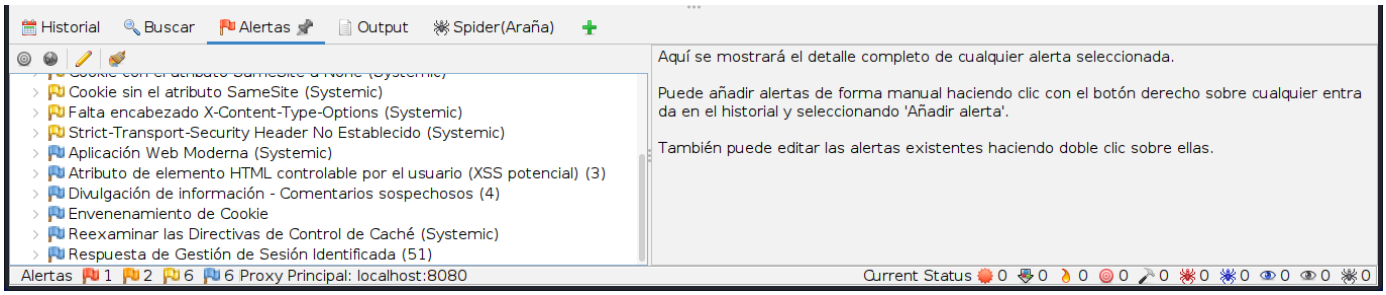




3) **Identificación y Categorización de Vulnerabilidades**: Se ejecuta un análisis de alertas generado por el escáner, clasificando los hallazgos según su nivel de riesgo (Alto, Medio, Bajo e Informativo).

3.1) Documentar 3 alertas de diferente tipo: Captura de pantalla de la sección de Alertas





La barra de estado inferior da el resumen exacto por niveles de riesgo:

- **1 Alerta Roja** (Riesgo Alto / High)
- **2 Alertas Naranjas** (Riesgo Medio / Medium)
- **6 Alertas Amarillas** (Riesgo Bajo / Low)
- **6 Alertas Azules** (Informativas / Informational)

(En total suman 15 alertas registradas)



Escogemos 3 diferentes alertas**:**

1. **Alerta 1 (Nivel Alto - Roja):** Librería JS Vulnerable
2. **Alerta 2 (Nivel Medio - Naranja):** Ausencia de Tokens Anti-CSRF
3. **Alerta 3 (Nivel Bajo - Amarilla):** Cookie Sin Flag HttpOnly

Cuadro de Alertas Seleccionadas

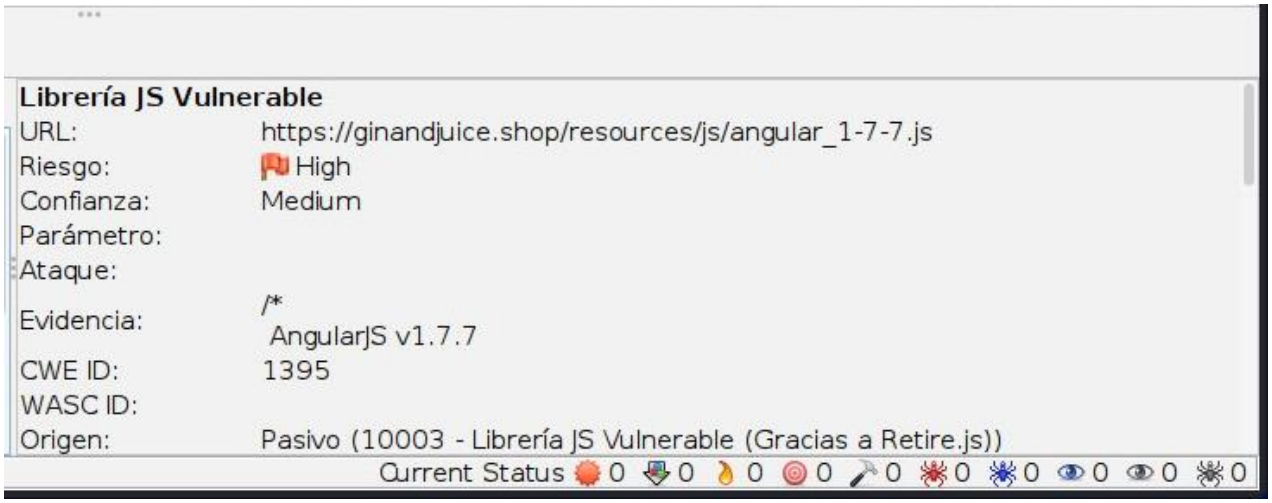
#	Nombre de la Alerta	Nivel de Riesgo	Descripción / Significado Sencillo
1	**Librería JS Vulnerable**	**Alto**	**Código desactualizado:** La página utiliza programas viejos en sus archivos de código. Esto permite que atacantes aprovechen fallas ya conocidas para hackear el sitio o controlar la pantalla del usuario.
2	**Ausencia de Tokens Anti-CSRF**	**Medio**	**Falta de candado en formularios:** Las páginas de entrada o formularios no comprueban si la petición la hizo el usuario real o una página falsa creada por un engaño (como un clic en un enlace de trampa).
3	**Cookie Sin Flag HttpOnly**	**Bajo**	**Llave de paso desprotegida:** Las "cookies" son como pases de entrada que recuerdan quién eres. Si no se protegen bien, un código malicioso en el navegador podría leerlas y robar la sesión de tu cuenta.

4) **Análisis Técnico de Hallazgos:** Se seleccionó y analizó a detalle la vulnerabilidad de mayor impacto (Librería JS Vulnerable - AngularJS v1.7.7), documentando su descripción, impacto y recomendaciones de solución.

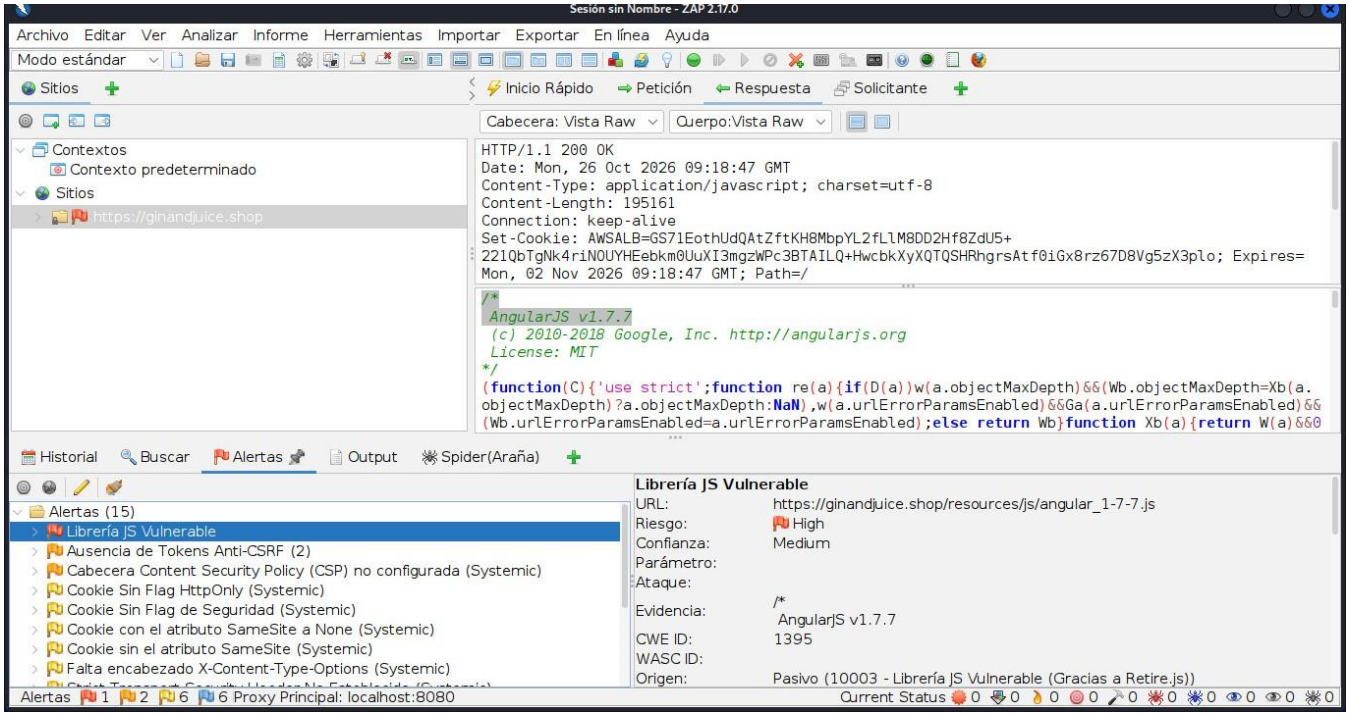


4.1) Ficha Técnica: Que documenta la alerta principal Librería JS Vulnerable (Vulnerable JS Library)

1. Nombre de la alerta	Librería JS Vulnerable (Vulnerable JS Library)
2. Nivel de riesgo	Alto (High)
3. URL o componente afectado	https://ginandjuice.shop/resources/js/
4. Parámetro afectado	Componente/Librería de JavaScript (Cliente)
5. Evidencia	Uso de versiones desactualizadas de archivos .js que contienen vulnerabilidades conocidas cargadas en el navegador
6. Descripción técnica	La página web utiliza librerías o código de JavaScript viejo/desactualizado. Es como si la casa usara un candado muy antiguo del cual ya todo el mundo sabe cómo abrirlo sin llave; un atacante puede aprovechar estas fallas conocidas para ejecutar código malicioso en la pantalla del usuario.
7. Impacto potencial	Un atacante podría robar la información del usuario, modificar lo que se muestra en la página web o redirigir al visitante a un sitio falso para robarle sus contraseñas
8. Recomendación	Actualizar todas las librerías y archivos de JavaScript a sus versiones más recientes y seguras, y darles mantenimiento periódico.







5) **Conclusiones y cierre del entorno:** Se redactaron los aprendizajes y retos de la práctica, y se restauró la configuración de red del navegador (Firefox) a su estado habitual (*Sin proxy*).

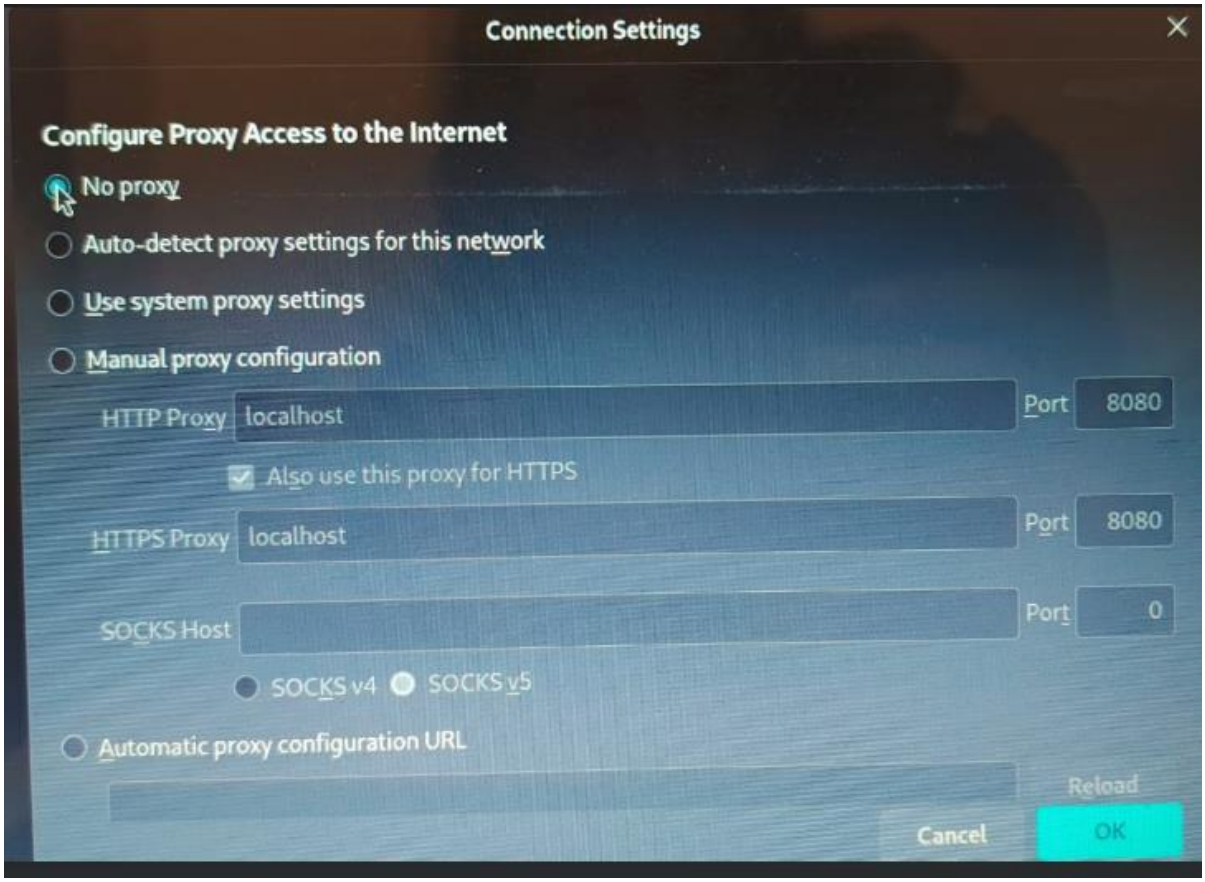
5.1) ¿Qué pasa con proxy?:

- Antes de empezar la práctica: Configuramos el navegador en Configuración manual del proxy (127.0.0.1:8080) para que ZAP pudiera "escuchar" y registrar todo lo que hicimos en la página web.
- Durante la práctica: Navegamos por el sitio objetivo mientras ZAP escaneaba y registraba las alertas.
- Al terminar la práctica: Cerramos la herramienta y regresamos el navegador a Sin proxy (No proxy).

5.2) ¿Para qué cerramos proxy?:

Para evitar errores de navegación: Si dejamos proxy activado en Firefox pero cerramos ZAP, el navegador intentará enviar todo el tráfico a un programa que ya no está abierto, mostrando el mensaje de error de *"Servidor proxy no disponible"*.





CONCLUSIONES Y REFLEXIONES FINALES

1. ¿Qué aprendí?

Durante esta evaluación de seguridad con OWASP ZAP, aprendí cómo se comporta el navegador, hasta los mecanismos de control que protegen al usuario.

Comprendí la diferencia fundamental entre las cookies (que actúan como una llave o pase para recordar la sesión mientras navegamos) y los tokens de seguridad (que funcionan como códigos de confirmación ocultos para autorizar acciones en los formularios). Asimismo, aprendí a utilizar un proxy intermediario para auditar el tráfico HTTP y detecté alertas importantes, como el uso de librerías de JavaScript desactualizadas, entendiendo que mantener los componentes actualizados es vital para evitar que atacantes exploten fallas conocidas.

2. ¿Qué fue lo más retador?



Lo más retador de esta actividad fue interpretar la información técnica que genera el escaneo. Me costó trabajo comprender cómo una sola acción o clic en el navegador web se traduce por detrás en múltiples líneas de tráfico HTTP (GET/POST) registradas en el historial de ZAP. Aprender a leer esas alertas y relacionarlas con las secciones visitadas fue un gran desafío.

3. ¿Qué revisaría a continuación?

Como siguientes pasos en mi formación dentro de ciberseguridad, me gustaría aprender y profundizar en cómo se crea una página web con HTML, Java, Java script y las bases de datos para comprender mejor cómo operan las vulnerabilidades críticas como la Inyección SQL. Asimismo, me agradaría revisar y configurar correctamente la seguridad de una aplicación o sitio web (como las políticas de contenido y cookies) para asegurar que esté protegido tanto de errores humanos como contra ataques.